TITLE OF THE PROJECT:-

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

Overview:

This project focuses on implementing and managing **Zero Trust Network Access (ZTNA)** using the cloud security platform provided by Zscaler. The aim is to provide **secure, identity-based access to internal applications** without exposing the organization's internal network to the internet.

Traditional security models rely on **VPN-based network access**, where once a user is authenticated, they gain broad access to the internal network. This approach can increase security risks because attackers who gain access to a VPN can potentially move laterally within the network. To solve this problem, the project adopts the **Zero Trust security model**, which follows the principle of **"Never Trust, Always Verify."**

In this system, users are granted access only to **specific applications rather than the entire network**. The implementation uses **Zscaler Private Access (ZPA)** to create a secure connection between authenticated users and internal applications. The platform verifies the **user identity, device posture, and access policies** before allowing access.

The system architecture includes components such as the **Zscaler Client Connector installed on user devices, Zscaler cloud services that enforce security policies, and App Connectors placed within the organization's network to provide secure outbound connectivity to applications. Authentication is integrated with identity providers like **Azure Active Directory** or other enterprise identity platforms to ensure strong identity verification.

By implementing this architecture, the project ensures that internal applications remain **hidden from the public internet**, reducing the attack surface. Access is granted only after verifying the user's identity and permissions, which enhances security and protects sensitive organizational resources.

S.No.	NAME	COLLEGE	CONTACT
1.	PONANITHA S	SHRI NEHRU MAHA VIDYALAYA COLLEGE OF ARTS & SCIENCES	anithaanitha29090@gmail.com
2.	VISHAL S	SHRI NEHRU MAHA VIDYALAYA COLLEGE OF ARTS & SCIENCES	vv4994918@gmail.com
3.	ELLILLARASI M	SHRI NEHRU MAHA VIDYALAYA COLLEGE OF ARTS & SCIENCES	ellilldharu@gmail.com

PROJECT DETAILS

TITLE OF THE PROJECT:-

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

INTRODUCTION

In today's digital world, organizations rely heavily on cloud services, remote work, and internet-based applications. Traditional network security models are no longer sufficient to protect sensitive data and internal systems. Most organizations previously depended on Virtual Private Networks (VPNs) to allow employees to access internal resources remotely. However, VPNs often provide broad network access once a user is authenticated, which increases the risk of cyberattacks and unauthorized access.

To overcome these limitations, modern organizations are adopting the **Zero Trust security model**. Zero Trust follows the principle of *"Never Trust, Always Verify,"* meaning that every user and device must be authenticated and authorized before accessing any resource. Instead of granting full network access, users are allowed to connect only to the specific applications they need. This significantly reduces the chances of internal threats and lateral movement by attackers.

This project focuses on implementing **Zero Trust Network Access (ZTNA)** using the cloud-based security platform provided by Zscaler. ZTNA enables secure, identity-based access to internal applications without exposing the organization's network to the public internet. The solution mainly uses Zscaler Private Access to create secure connections between users and internal applications through the Zscaler cloud.

ABSTRACT

This project focuses on implementing **Zero Trust Network Access (ZTNA)** to provide secure and controlled access to internal applications without exposing the internal network. Traditional security models rely on Virtual Private Networks (VPNs), which often allow users to access large parts of the network after authentication. This increases the risk of cyberattacks and unauthorized access. To overcome these limitations, the Zero Trust security model is used, which follows the principle of *"Never Trust, Always Verify."*

The implementation in this project uses the cloud security platform provided by Zscaler. The system mainly utilizes Zscaler Private Access to create secure, identity-based connections between users and internal applications. Instead of granting full network access, users are allowed to access only specific applications based on predefined policies and permissions.

User authentication is integrated with identity management systems such as Azure Active Directory to ensure that only authorized users can access the resources. The Zscaler Client Connector installed on user devices helps establish a secure connection with the Zscaler cloud and continuously verifies user identity and device security status.

By implementing Zero Trust Network Access, the system improves overall security, reduces the attack surface, and protects sensitive organizational data. This project demonstrates how modern security solutions can replace traditional VPN-based access and provide a more secure, scalable, and efficient method for remote application access.

Use Case Scenarios

1. Secure Remote Employee Access

Employees working remotely can securely access internal company applications through Zscaler Private Access provided by Zscaler. Access is granted only after verifying the user's identity and device security status. This ensures that only authorized users can connect to specific applications instead of accessing the entire internal network.

2. Third-Party Vendor Access Control

Organizations often allow vendors, contractors, or partners to access certain internal applications. With identity-based policies, these external users can be granted limited access only to the applications required for their tasks. This approach prevents exposure of the complete network while maintaining secure collaboration.

3. Protection of Sensitive Applications

Critical business systems such as financial platforms, internal databases, or management systems can be protected using application-specific security policies. Access is allowed only to verified users and secure devices, reducing the risk of unauthorized access and protecting sensitive organizational data.

4. Secure Access from Untrusted Networks

Employees may need to access company resources from public or untrusted networks such as cafés, airports, or hotels. Using Zscaler Private Access, a secure connection is established between the user and the application through the Zscaler cloud. This protects data and ensures safe communication without exposing the internal infrastructure.

5. Data Protection through Content-Aware Access

Organizations can apply content-aware security policies to control how sensitive information is used. These policies can restrict activities such as downloading, copying, or sharing confidential files. This helps prevent data leakage and ensures that critical business information remains protected.

STAGE 1

S.NO	Vulnerability name	CWE/CVE no.
1	Sensitive Cookie with Improper SameSite Attribute	CWE-1275
2	ASP.NET Misconfiguration: Improper Model Validation	CWE-1174
3	Dependency on Vulnerable Third-Party Component	CWE-1395
4	Use of Predictable Algorithm in Random Number Generator	CWE-1241
5	Improper Neutralization of Special Elements used in an Expression Language Statement ('Expression Language Injection')	CWE 917
6	Excessive Attack Surface	CWE 1125
7	Use of Default Password	CWE 1393
8	Improper Export of Android Application Components	CWE 926
9	Insufficient Logging	CWE 778
10	Missing Custom Error Page	CWE 756

VULNERABILITY ASSESSMENT REPORT

1. **Vulnerability Name:** Broken Access Control
   CWE/CVE Number: CWE-285
   OWASP Category: A01:2025 Improper Authorization

DESCRIPTION:
Improper Authorization occurs when an application fails to correctly verify whether a user has permission to access a specific resource or perform a particular action. Due to this weakness, attackers may bypass access controls and gain unauthorized privileges.

BUSINESS IMPACT:
Unauthorized users may access confidential data, modify sensitive information, or perform administrative operations. This can result in data breaches, financial losses, and damage to the organization's reputation.

2. **Vulnerability Name:** Security Misconfiguration
   CWE/CVE Number: CWE-614
   OWASP Category: A02:2025 Sensitive Cookie Without Secure Attribute

DESCRIPTION:
This vulnerability occurs when cookies that contain sensitive information, such as session identifiers, are transmitted without the **Secure attribute**. Without this attribute, cookies may be sent through unencrypted HTTP connections, making them vulnerable to interception by attackers.

BUSINESS IMPACT:
Attackers may capture session cookies and hijack user sessions. This can allow unauthorized access to user accounts and sensitive data.

3. **Vulnerability Name:** Software Supply Chain Failures
   CWE/CVE Number: CWE-1104
   OWASP Category: A03:2025 Use of Unmaintained Third-Party Components

DESCRIPTION:
Applications often rely on external libraries or frameworks. When these components are no longer maintained or updated, they may contain known security vulnerabilities that attackers can exploit.

BUSINESS IMPACT:
Exploitation of vulnerable components may allow attackers to execute malicious code, compromise application security, and access confidential information.

4. **Vulnerability Name:** Cryptographic Failures
   CWE/CVE Number: CWE-321
   OWASP Category: A04:2025 Use of Hard-coded Cryptographic Key

DESCRIPTION:
Hard-coded cryptographic keys occur when encryption keys are directly embedded in the application source code. If attackers gain access to the code, they may extract the key and decrypt sensitive information.

BUSINESS IMPACT:
Sensitive data such as passwords, personal information, and financial records may be exposed, leading to major security breaches and regulatory consequences.

5. **Vulnerability Name:** Injection
   CWE/CVE Number: CWE-89
   OWASP Category: A05:2025 SQL Injection

DESCRIPTION:
SQL Injection occurs when user input is included in database queries without proper validation or parameterization. Attackers can manipulate these queries to retrieve, modify, or delete data stored in the database.

BUSINESS IMPACT:
Attackers may access confidential information, alter stored records, or delete critical data, causing severe disruption to business operations.

6. **Vulnerability Name:** Insecure Design
   CWE/CVE Number: CWE-693
   OWASP Category: A06:2025 Protection Mechanism Failure

DESCRIPTION:
Protection mechanism failure occurs when security controls such as authentication, authorization, or validation mechanisms are poorly designed or incorrectly implemented. This weakness allows attackers to bypass important security protections.

BUSINESS IMPACT:
Attackers may gain unauthorized system access, manipulate application functionality, or disrupt services.

7. **Vulnerability Name:** Identification and Authentication Failures
   CWE/CVE Number: CWE-521
   OWASP Category: A07:2025 Weak Password Requirement

DESCRIPTION:
This vulnerability occurs when an application allows users to create weak or easily guessable passwords. Without strong password policies, attackers can perform brute-force or dictionary attacks to gain unauthorized access.

BUSINESS IMPACT:
Compromised user accounts may lead to unauthorized system access, exposure of sensitive data, and financial losses.

8. **Vulnerability Name:** Software and Data Integrity Failures
   CWE/CVE Number: CWE-353
   OWASP Category: A08:2025 Improper Integrity Check

DESCRIPTION:
Improper integrity validation occurs when software updates, files, or external data are not verified before execution. Attackers may modify these resources or inject malicious code.

BUSINESS IMPACT:
Compromised files or updates may introduce malware, steal sensitive information, or disrupt system functionality.

9. **Vulnerability Name:** Security Logging and Monitoring Failures
   CWE/CVE Number: CWE-778
   OWASP Category: A09:2025 Insufficient Logging and Monitoring

DESCRIPTION:
This vulnerability occurs when applications fail to properly log or monitor important security events. Without adequate logging, suspicious activities or attacks may go undetected.

BUSINESS IMPACT:
Attackers may remain undetected for extended periods, increasing the damage caused by security incidents.

10. **Vulnerability Name**: Improper Handling of Exceptional Conditions

    CWE/CVE Number: CWE-703

    OWASP Category: A10:2025 Security Misconfiguration / Error Handling Issues

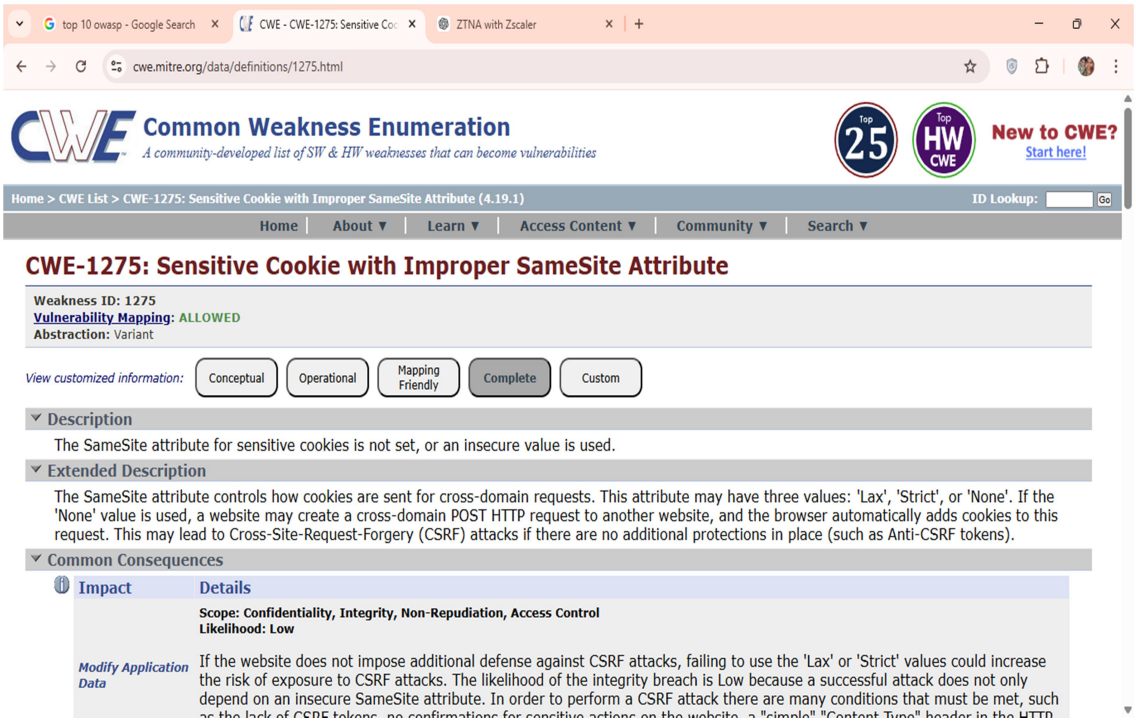
DESCRIPTION:

Improper handling of exceptional conditions occurs when an application fails to properly manage unexpected errors or abnormal situations. Attackers may exploit these weaknesses to cause system failures or bypass security mechanisms.

BUSINESS IMPACT:

This vulnerability may lead to system instability, service disruption, and potential security breaches.

SCREEN SHOTS



top 10 owasp - Google Search | CWE - CWE-1174: ASP.NET Mis | ZTNA with Zscaler

cwe.mitre.org/data/definitions/1174.html

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-1174: ASP.NET Misconfiguration: Improper Model Validation (4.19.1) | ID Lookup: Go

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-1174: ASP.NET Misconfiguration: Improper Model Validation

Weakness ID: 1174
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The ASP.NET application does not use, or incorrectly uses, the model validation framework.

Common Consequences

Impact	Details
Unexpected State	**Scope: Integrity** Unchecked input leads to cross-site scripting, process control, and SQL injection vulnerabilities, among others.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	*Type*	*ID*	*Name*
ChildOf	B	1173	Improper Use of Validation Framework

tps://cwe.mitre.org/index.html

top 10 owasp - Google Search | CWE - CWE-1395: Dependency | ZTNA with Zscaler

cwe.mitre.org/data/definitions/1395.html

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-1395: Dependency on Vulnerable Third-Party Component (4.19.1) | ID Lookup: Go

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-1395: Dependency on Vulnerable Third-Party Component

Weakness ID: 1395
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product has a dependency on a third-party component that contains one or more known vulnerabilities.

Extended Description

Many products are large enough or complex enough that part of their functionality uses libraries, modules, or other intellectual property developed by third parties who are not the product creator. For example, even an entire operating system might be from a third-party supplier in some hardware products. Whether open or closed source, these components may contain publicly known vulnerabilities that could be exploited by adversaries to compromise the product.

Common Consequences

Impact	Details
Varies by Context	**Scope: Confidentiality, Integrity, Availability** The consequences vary widely, depending on the vulnerabilities that exist in the component; how those vulnerabilities can be "reached" by adversaries, as the exploitation paths and attack surface will vary depending on how the component is used; and the criticality of the privilege levels and features for which the product relies on the component.

Stage 2:

TITLE: Nessus

Overview:

Nessus is a popular vulnerability scanning tool developed by **Tenable**. It is widely used in cybersecurity to identify security weaknesses in computers, networks, servers, and applications. Nessus helps organizations detect vulnerabilities before attackers can exploit them, making it an important tool for maintaining system security.

Nessus works by scanning target systems using thousands of plugins that check for known vulnerabilities such as missing patches, weak passwords, open ports, and misconfigured services. During the scan, it analyzes the system and compares the results with its vulnerability database to identify potential security risks. The detected vulnerabilities are then categorized based on their severity level.

After completing the scan, Nessus generates detailed reports that include information about the vulnerability, its severity, possible impact, and recommended solutions to fix the issue. These reports help security professionals understand the risks and take corrective actions. Because of its accuracy, regular updates, and easy-to-use interface, Nessus is widely used for vulnerability assessment and security auditing in many organizations.

s.no	Vulnerability name	Severity	plugins
1	Service Detection	info	206982
2	Sensitive Cookie Without Secure Attribute	medium	57582
3	SQL Injection	High	34396

REPORT:

Target website: https://public-firing-range.appspot.com
Target ip address: 44.228.249.3

Vulnerability name: Service Detection

Severity: info

Plugins: 206982

DESCRIPTION:

Service Detection is a scanning technique used by vulnerability scanners to identify the services running on open ports of a system.

During a security scan, the scanner connects to different ports on the target system and analyzes responses to determine which service is running. For example, it may detect services such as:

- Web servers (HTTP / HTTPS)
- FTP servers
- SSH services
- Database services
- Email services (IMAP, SMTP)

SOLUTION:

Disable unnecessary services, close unused ports using firewall rules, restrict service access to trusted networks, and regularly monitor systems with vulnerability scanners to reduce the attack surface.

BUSINESS IMAPCT:

Service detection reveals information about the services running on a system. Attackers can use this information to identify potential targets and attempt attacks on vulnerable services. This may increase the attack surface and could lead to unauthorized access or exploitation if services are not properly secured.

REPORT :

Target Website: http://demo.owasp-juice.shop
Target ip address: 81.169.145.156
Vulnerability name: Sensitive Cookie Without Secure Attribute

Severity: Medium

Plugins: 57582

DESCRIPTION:

Sensitive Cookie Without Secure Attribute occurs when a web application sends cookies without enabling the **Secure flag**. Without this flag, cookies can be transmitted over **unencrypted HTTP connections** instead of only through HTTPS.
This means the cookie containing sensitive information such as **session IDs or authentication tokens** can be intercepted by attackers during network communication.

SOLUTION:

Configure the web application to set the **Secure attribute** for cookies so that they are only transmitted over HTTPS connections. Also ensure that the website uses HTTPS for all sensitive communications.

BUSINESS IMPACT:

If cookies are transmitted without the Secure attribute, attackers may intercept session cookies and perform **session hijacking**. This can allow unauthorized access to user accounts and sensitive information, leading to security risks and potential data breaches.

REPORT Target website: http://dvwa.co.uk

Target ip Address**:** 172.67.154.147

Vulnerability name: SQL Injection

Severity: High

Plugins: 34396

DESCRIPTION:

SQL Injection is a web security vulnerability that allows attackers to interfere with database queries made by an application. It occurs when user input is not properly validated or sanitized before being used in SQL queries.
Attackers can insert malicious SQL commands to access, modify, or delete data stored in the database.

SOLUTION:

Use **parameterized queries or prepared statements**, validate user inputs, and implement proper input sanitization. Web applications should also use secure coding practices and apply regular security testing.

BUSINESS IMPACT:

SQL Injection can allow attackers to gain unauthorized access to the database and sensitive information such as user credentials or financial data. This may lead to **data theft, data modification, or complete database compromise**, which can severely impact business operations and customer trust.

Stage 3:

Tittle:

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

Overview:

This stage focuses on implementing a **Zero Trust access model** where users are granted access only to the applications they need based on identity, device security, and application sensitivity. Instead of giving full network access, ZTNA provides **secure, application-level access** by verifying the user, checking device posture, evaluating application risk, and applying content-aware policies. This approach helps organizations enforce **least-privilege access**, reduce attack surfaces, and protect sensitive business data.

Identity :

Identity-based access ensures that only **authenticated and authorized users** can access specific applications. Access policies are defined based on user identity, roles, and organizational groups, ensuring that users only access resources necessary for their work.

Device posture :

Device posture checks the **security status of the user's device** before granting access. ZTNA verifies whether the device complies with security requirements such as updated operating systems, security patches, and endpoint protection. Only trusted and secure devices are allowed to access internal applications.

Application risk :

Application risk evaluation helps determine the **security level and sensitivity of each application**. High-risk or critical applications are protected with stricter access controls, ensuring that only authorized users can interact with them.

Content aware access :

Content aware access controls user access based on the **type and sensitivity of the data within applications**. It monitors user activities and applies security policies to prevent unauthorized downloading, sharing, or transfer of confidential information, helping to protect sensitive business data.

CONCLUSION :

Stage 1 :

Stage 1 focuses on identifying common web application vulnerabilities based on the **OWASP Top 10 security risks**. The analysis highlights several security weaknesses such as improper authorization, SQL injection, and insufficient logging. Understanding these vulnerabilities helps organizations recognize potential threats and improve secure coding practices. Addressing these issues is essential to protect sensitive data, maintain system integrity, and ensure secure application development.

Stage 2 :

Stage 2 demonstrates the use of the vulnerability scanning tool **Nessus** to detect security weaknesses in systems and applications. The scan results identified issues such as service detection, sensitive cookie misconfiguration, and SQL injection risks. By analyzing these findings and implementing recommended solutions, organizations can reduce security risks, strengthen system defenses, and improve overall network security posture.

Stage 3 :

Stage 3 focuses on implementing **Zero Trust security principles** using **Zscaler Private Access (ZTNA)**. By enforcing identity-based access, verifying device posture, evaluating application risk, and applying content-aware policies, organizations can ensure that users only access the resources they need. This least-privilege approach significantly reduces the attack surface, improves data protection, and enhances overall enterprise security.

FUTURE SCOPE

Stage 1 – Vulnerability Identification

In the future, vulnerability identification can be improved by integrating **advanced security testing techniques** such as automated vulnerability scanners, penetration testing, and secure code analysis. Organizations can also adopt continuous security monitoring to detect new vulnerabilities early and apply security patches regularly to maintain strong application security.

Stage 2 – Vulnerability Scanning

Future improvements in vulnerability scanning using tools like Nessus can include **continuous automated scanning and real-time threat detection**. Integrating scanning tools with security management platforms and threat intelligence systems will help organizations quickly identify and respond to emerging threats, improving overall network security.

Stage 3 – Secure Access with ZTNA

In the future, secure access systems such as Zscaler Private Access can be enhanced with **AI-based threat detection, stronger device posture verification, and adaptive access policies**. Organizations can further strengthen the Zero Trust model by continuously analyzing user behavior and automatically adjusting access controls to protect sensitive applications and data.

Topics Explored : OWASP top 10,scanning , Vulnerability ,awareness, identity

Tools Explored: Zscaler,nessus,Owasp,hackthissite